OANRO release report

Every file changed for this release, what changed and why. Prepared 29 October 2026. Compared with what is on GitHub (main) before this push.

> **In short.** 107 files changed (+10,164 lines, -205 lines) across 12 commits. The biggest part is a new, optional shop assistant (JUNO) that stays **switched off** until you set `ASSISTANT_ENABLED=true`. The rest is security hardening, safer sign-up, real 404 pages, a more compact product display, and two bug fixes.

What visitors and staff will notice after this goes live

- **Products:** compact grids (3 across on phones, 6 on wide desktops); the whole product photo is always shown; smaller hover button and text; size chips are smaller and fit any size set.
- **Back to top button:** smaller, at the bottom left; the owner can switch it on or off in Admin > Products & sections.
- **Sign-up and sign-in:** Show/Hide password eye, typo hint for email, addresses that cannot receive mail are refused, resend-verification button.
- **Unknown, draft, hidden or archived product pages** now return a real 404 page (better for search engines).
- **Home page** no longer jumps on small phones while the headline animates.
- **Privacy page** has a new section about the assistant. The assistant itself does not appear until it is switched on.

Two bugs fixed (both existed before)

- **Cash on delivery:** after ordering, the success screen said "Pay 0 in cash". It now shows the real amount to pay the delivery person.
- **Admin exports and labels:** the CSV export button and the order labels panel were refused (403) in real browsers. They now work. Anything that changes data, and any request from another site, is still refused.

> **Not part of this push.** The database migration (`drizzle/0018_assistant.sql`) is **not** run by pushing. It is only needed before the assistant is switched on, creates new tables only, and must be run on the real database only with the owner's approval. Nothing here switches the assistant on.

Commits in this push

Commit	Summary
`fcece80`	Security headers, rate limits, DB connection fix, intro toggle, new cookie bar
`15568e2`	Add JUNO, the OANRO shopping assistant (chat, voice, admin, privacy notice)
`61191fd`	Auth forms: password Show/Hide, email typo hint, resend verification button
`b51499a`	Sign-up: refuse email domains that cannot receive mail (DNS check) and test resend behaviour
`d4e6ad4`	Security fixes from the code review: nodemailer 10.2.1, safe Origin check, view limit, secret helper
`94a5fd6`	Docs: review inventory, baseline, auth findings, change log and API/admin/assistant review
`1636ebd`	Product pages: return a real 404 for unknown, draft, hidden and archived products
`902f803`	Home hero: stop the headline animation from shifting the page (layout shift)
`ef206dc`	Docs: second review pass (data, consent, SEO, performance) and F19/F22 fix results
`f4f6811`	Fix cash-on-delivery amount on the success screen and admin read-only requests

f6b884d	Storefront and assistant polish: product grids, photo cards, floating buttons, loading state
641e35c	Docs: go-live notes, checkpoint log and full functional check results

1. Shop assistant JUNO (new feature, switched OFF by default)

A free-tier AI shopping assistant with chat, voice, an admin page and a privacy notice. Nothing of it loads or is reachable unless ASSISTANT_ENABLED=true is set, so pushing this code does not turn it on.

File	Lines	What changed	Why
src/lib/assistant/config.ts	+59 -0	New. Reads the on/off switch, limits and provider settings.	One place for every assistant setting; the feature stays off unless switched on.
src/lib/assistant/engine.ts	+170 -0	New. Decides how each message is answered (rules, FAQ, AI, fallbacks).	Keeps answers truthful and falls back safely when the AI is unavailable or the free limit is reached.
src/lib/assistant/providers.ts	+50 -0	New. Groq as main AI, Cloudflare as backup.	Free-only AI providers with automatic fallback.
src/lib/assistant/tools.ts	+95 -0	New. Tools the AI may call: product search, delivery rules, order tracking link.	The AI can only read real shop data; prices are verified against the database.
src/lib/assistant/prompt.ts	+25 -0	New. The instructions given to the AI.	Tone, language (English, Bangla, Banglish), currency in Taka, refusal of off-topic requests.
src/lib/assistant/sanitize.ts	+99 -0	New. Removes personal data and unsafe links from stored text and replies.	Privacy: phone numbers, emails and IDs are redacted; only allowed links appear.
src/lib/assistant/match.ts	+99 -0	New. Fuzzy matching of product names and typos.	Finds the right product for misspelled or Banglish queries.
src/lib/assistant/language.ts	+25 -0	New. Detects English, Bangla or Banglish.	Reply in the visitor's language.
src/lib/assistant/messages.ts	+45 -0	New. Fixed texts (greeting, limits, errors) in English and Bangla.	Short, consistent messages when the AI is not used.
src/lib/assistant/server.ts	+123 -0	New. Request handling, sessions, limits, safety checks.	Same-site checks, per-visitor limits, daily budget that fails closed.
src/lib/assistant/store.ts	+216 -0	New. Saves chats, usage, FAQ and settings in the database.	Conversations kept sanitised for 30 days; usage counted per day.
src/lib/assistant/types.ts	+37 -0	New. Shared types.	Type safety across the assistant.
src/lib/assistant/tracking.ts	+18 -0	New. Safe order-tracking helper.	Tracking needs order number plus phone, never typed into the chat.
src/lib/assistant/voice-core.ts	+91 -0	New. Voice logic (listening, errors, permission messages).	Microphone use with short, clear messages.
src/lib/assistant/transcribe.ts	+27 -0	New. Speech to text through Groq Whisper.	Voice input; audio is not stored.
src/lib/assistant/speech.ts	+39 -0	New. Reading replies aloud.	Optional read-aloud.
src/lib/assistant/weather.ts	+83 -0	New. Local weather from MET Norway (rounded location, cached).	Header scene follows real weather; no precise location is kept.

src/lib/assistant/sky.ts	+38 -0	New. Maps weather and time to the sky scene.	Day, night, rain, snow and clouds in the header.
src/lib/assistant/chat-state.ts	+9 -0	New. Small helper that keeps chat messages unique when Retry is used.	Fixes the duplicate React key error on Retry.
src/app/api/assistant/route.ts	+57 -0	New. Chat endpoint.	Main chat API, protected by same-site and rate limits.
src/app/api/assistant/handoff/route.ts	+52 -0	New. 'Message our team' endpoint.	Creates a normal inquiry labelled Shop assistant; needs consent.
src/app/api/assistant/track/route.ts	+32 -0	New. Order tracking from the assistant.	Looks up an order with order number and phone.
src/app/api/assistant/transcribe/route.ts	+44 -0	New. Voice upload endpoint.	Speech to text with size and rate limits.
src/app/api/assistant/weather/route.ts	+25 -0	New. Weather endpoint for the header.	Rate limited, cached, fail closed.
src/app/api/admin/assistant/faq/route.ts	+9 -0	New. Admin FAQ answers.	Owner can add answers that need no AI.
src/app/api/admin/assistant/settings/route.ts	+11 -0	New. Admin on/off and tone settings.	Owner control without a code change.
src/app/api/admin/assistant/unanswered/route.ts	+7 -0	New. Mark unanswered questions handled.	Owner can work through questions the assistant could not answer.
src/app/api/cron/assistant-cleanup/route.ts	+13 -0	New. Daily cleanup job.	Deletes chats older than 30 days; refuses requests without the secret.
src/app/admin/assistant/page.tsx	+80 -0	New. Admin page: usage, switches, FAQ, unanswered questions, conversations.	Owner overview and control.
src/components/assistant-admin.tsx	+70 -0	New. Admin page widgets.	Forms for settings and FAQ.
src/components/assistant-widget.tsx	+174 -0	New. The chat window: header scene, messages, input, close rocket.	The visitor-facing assistant.
src/components/assistant-launcher.tsx	+38 -0	New. The round launcher button.	Opens the chat; 10% smaller and a little lower in this release.
src/components/assistant-loader.tsx	+7 -0	New. Loads the assistant only when enabled.	No assistant code is sent to visitors when it is off.
src/components/assistant-thinking.tsx	+19 -0	New. 'Juno is thinking' loading indicator.	Approved design; shown only while a reply is being made.
src/components/assistant-cards.tsx	+65 -0	New. Product and info cards inside the chat.	Photo, price, availability, size and colour choice, Add to bag.
src/components/assistant-forms.tsx	+66 -0	New. Hand-off and tracking forms.	Consent checkbox and clear fields.
src/components/assistant-voice.tsx	+207 -0	New. Microphone buttons and permission handling.	Browser asks for the microphone on click; short notices.
src/components/assistant-sky.tsx	+108 -0	New. Tokyo skyline header scene.	Follows real weather and time of day in the site colours.
src/components/assistant-weather.tsx	+29 -0	New. Weather chip.	Temperature and condition in glass style.
src/components/assistant-clock.tsx	+20 -0	New. Local time and date chip.	Visitor's own time zone.

src/components/assistant-close.tsx	+23 -0	New. Close button (rocket with X).	From the owner's supplied design.
src/components/assistant-mascot.tsx	+15 -0	New. Rocket icon.	Recoloured to the site palette.
src/components/assistant-rich-text.tsx	+8 -0	New. Safe text formatting for replies.	No raw HTML from the AI is ever rendered.
src/app/assistant.css	+338 -0	New. All assistant styles.	Kept in its own file so it is not loaded when the assistant is off.
public/assistant/rocket-mint.svg	+1 -0	New. Animated rocket.	Owner's rocket recoloured to the site palette.
public/assistant/rocket-mint-static.svg	+1 -0	New. Still rocket.	Used when the visitor prefers reduced motion.
src/app/privacy/page.tsx	+21 -1	Added a section about the assistant.	Tells visitors what the assistant stores and which providers it uses.
src/components/privacy-center.tsx	+6 -4	Small wording additions.	Privacy choices mention the assistant and voice.
src/lib/permissions.ts	+6 -4	Added assistant.view and assistant.edit; updated the 'Site switches' text.	Staff roles can be given the assistant pages; text mentions the back-to-top switch.
src/lib/admin-menu.ts	+1 -0	Added the Assistant menu entry.	Admin navigation.
src/components/lead-inbox.tsx	+1 -0	Shows 'Source: Shop assistant chat' for hand-off inquiries.	Staff can see where a message came from.
src/lib/db/schema.ts	+52 -0	Added 7 assistant tables.	Chat, usage, FAQ, settings, hand-offs, unanswered questions.
tests/assistant.test.ts	+513 -0	New. 513 lines of tests for the assistant.	Safety, limits, sanitising, tracking, retry state.

2. Database migration (NOT run by the push)

Only needed before the assistant is switched on. It creates new tables and does not change or delete any existing table. It must be run on the real database only with the owner's approval.

File	Lines	What changed	Why
drizzle/0018_assistant.sql	+92 -0	New. Creates the 7 assistant tables, indexes and links to existing users and inquiries.	Storage for the assistant; no existing table is altered.
drizzle/meta/0018_snapshot.json	+4602 -0	New. Migration snapshot.	Required by the migration tool.
drizzle/meta/_journal.json	+7 -0	Added the 0018 entry.	Migration order.

3. Security and reliability

Earlier hardening work plus the code-review fixes.

File	Lines	What changed	Why
next.config.ts	+42 -3	Added security headers including a Content-Security-Policy and a microphone permission for voice.	Blocks injected scripts; only listed sources may load.
src/lib/rate-limit.ts	+32 -0	New. Per-visitor limits stored in the database.	Limits for tracking, discount code checks, views, newsletter.
src/lib/same-host.ts	+9 -0	New. Safe same-site (Origin) check.	A missing or odd Origin counts as 'no', never an error.

src/lib/app-secret.ts	+19 -0	New. One helper for the server secret.	Warns in production if BETTER_AUTH_SECRET is missing.
src/lib/db/index.ts	+13 -1	Database connection: IPv4 first, explicit strict SSL mode.	Fixes intermittent connection failures; same security.
src/lib/two-factor-policy.ts	+11 -2	Retries once on a dropped connection.	A network blip no longer crashes admin pages.
src/lib/customer-mail.ts	+2 -1	Uses the shared secret helper for unsubscribe links.	Consistent secret handling.
src/lib/admin-api.ts	+8 -1	Admin API accepts read-only same-origin GET requests without an Origin header.	Fixes the admin CSV export and order labels panel, which were refused in real browsers. Changes to data and foreign origins are still refused.
src/lib/consent.ts	+6 -0	Recent-products reader checks consent on every read.	Personalisation only with permission.
src/app/api/inquiries/route.ts	+4 -3	Uses the shared Origin and secret helpers.	Same behaviour, less duplicated code.
src/app/api/newsletter/route.ts	+5 -1	Same-site check and 5 sign-ups per visitor per hour.	Stops abuse of the newsletter form.
src/app/api/discounts/check/route.ts	+3 -0	20 code checks per visitor per 10 minutes.	Discount codes cannot be guessed.
src/app/api/order-status/route.ts	+3 -0	15 lookups per visitor per 10 minutes.	Order lookups cannot be brute-forced.
src/app/api/track/view/route.ts	+4 -1	60 counted views per visitor per 10 minutes.	One script cannot push a product up the popular list.
package.json	+6 -2	Added AI libraries and zod; nodemailer 10.1.0 to 10.2.1.	Assistant dependencies and a security update.
package-lock.json	+145 -80	Matching lock file changes.	Reproducible installs.
vercel.json	+4 -1	Added the daily assistant cleanup job.	Old chats are deleted automatically.
eslint.config.mjs	+1 -1	Ignores local build and test-database folders.	Lint only checks real source.
.gitignore	+11 -0	Ignores local test-database and tool folders.	Local-only files are never pushed.
.env.example	+34 -0	New. Lists every setting with safe placeholders.	Documents what to set on the live host; no real secrets.
tests/safe-fixes.test.ts	+37 -0	New. Tests for the review fixes.	Keeps the fixes from regressing.

4. Sign-in and sign-up

File	Lines	What changed	Why
src/components/auth-panel.tsx	+61 -5	Show/Hide password, email typo hint, 'resend verification' button, clearer messages.	Fewer failed sign-ups and support questions.
src/components/password-field.tsx	+35 -0	New. Password field with the eye icon inside the field.	Approved design; keyboard and screen-reader friendly.
src/components/security-panel.tsx	+2 -1	Uses the new password field.	Consistency.
src/lib/auth-factory.ts	+12 -1	Checks that an email's domain can receive mail at sign-up.	Stops typo addresses like gmial.com.

src/lib/auth.ts	+2 -0	Connects the domain check.	Wiring.
src/lib/email-domain.ts	+43 -0	New. Mail-domain check using DNS.	Temporary DNS trouble never blocks a sign-up.
src/lib/email-typo.ts	+38 -0	New. Suggests the likely correct address.	Helpful hint for common typos.
tests/email-check.test.ts	+76 -0	New. Tests for the checks.	Quality.
tests/resend-verification.test.ts	+50 -0	New. Tests for resending verification.	Quality.

5. Storefront changes in this release

File	Lines	What changed	Why
src/app/v2.css	+120 -55	Compact product grids, 4:5 photo cards that never crop, smaller hover button and text, hero line fix, 24px tap targets, floating buttons layout.	Online-shop density (3 across on phones), whole photo always visible, no layout shift, better touch targets.
src/app/globals.css	+29 -5	Smaller responsive size chips, footer and shelf tap targets, admin card style.	Size selector works for any brand's size set on phone and desktop.
src/components/home-v2.tsx	+2 -2	Adds a products-only class to the shop grid.	So service cards keep their size.
src/components/site-extras.tsx	+10 -5	Back-to-top button: smaller, bottom left, can be switched off; newsletter shows clear messages.	Owner control; the sign-up says why it failed (too many tries, service down).
src/app/layout.tsx	+7 -2	Passes the back-to-top switch to the button.	Wiring.
src/lib/website-sections.ts	+6 -4	New switch 'back-to-top' (on when missing).	No migration needed; same table as the other site switches.
src/app/admin/sections/page.tsx	+4 -0	New 'Back to top' card with ON/OFF switch.	Owner can turn the button on or off.
src/components/checkout-form.tsx	+4 -3	Success screen keeps the cash-on-delivery amount.	Fixes 'Pay 0 in cash' shown after an order (bug in the original).
src/lib/site-content-data.ts	+3 -1	Logo intro is off by default.	Matches the live site before the switch existed.
src/app/loading.tsx	+0 -7	Removed.	Product pages now return real 404s; the generic loading skeleton interfered.
src/app/products/[slug]/loading.tsx	+0 -8	Removed.	Same reason: unknown, draft, hidden and archived products return a real 404.

6. Documents

File	Lines	What changed	Why
docs/assistant-setup.md	+66 -0	New. How to set up and switch on the assistant.	Steps for the owner.
docs/assistant-handover.md	+44 -0	New. Handover notes and test list.	For whoever maintains it.
docs/assistant-checkpoint.md	+122 -0	New. Dated log of decisions and checks.	Full history of this work.

`docs/assistant-go-live.md`	+125 -0	New. Release notes, live-change table, go-live steps, rollback, checks.	Everything needed to go live safely.
`docs/review/00-file-inventory.md`	+423 -0	New. Inventory of every file.	Code review.
`docs/review/01-baseline-and-scope.md`	+44 -0	New. Review baseline.	Code review.
`docs/review/02-auth-first-findings.md`	+40 -0	New. Sign-in findings.	Code review.
`docs/review/03-change-log-group-b.md`	+105 -0	New. Change log.	Code review.
`docs/review/04-api-admin-assistant-review.md`	+41 -0	New. API, admin and assistant review.	Code review.
`docs/review/05-data-seo-performance-review.md`	+83 -0	New. Data, consent, SEO and performance review.	Code review.

Checks done before this push

- Typecheck clean, lint 0 errors, 70 of 71 tests pass. The one failing test (RBAC) fails the same way on the original code.
- Production build passes with the assistant on and off. With it off there is no assistant markup, no assistant code sent to visitors, and its APIs answer 403.
- Responsive audit: 18 pages at 6 phone, tablet and desktop widths: no sideways scroll, no console errors, no failed requests, no broken images.
- Customer side: sign-up with email verification, sign-in, password reset by email, account, order tracking, bag, checkout by bKash and cash on delivery, stock reserved and given back, newsletter with unsubscribe, all inquiry forms.
- Admin side: all 19 admin pages, approve / ship / out for delivery / delivered / reject with the customer email at each step, cash-on-delivery cash received, reports, inquiries, discount codes, announcement bar, products, staff invite email, CSV exports, scheduled jobs refusing strangers.
- Assistant (live AI): price answers with a product card, Bangla answers, order-tracking form, hand-off to a person creating an inquiry, free-limit and rapid-message limits handled gracefully.
- No secrets, passwords or keys in the changes. Test data created during checking was removed from the local test database. The real database was never touched by this work.

Not checked, and still to do by the owner

- Google sign-in: add `https://oanro.com/api/auth/callback/google` (and the www form if used) to the Google Cloud OAuth client.
- Email to customers: verify the OANRO domain in Resend (the test sender only reaches the Resend account owner).
- Rotate the Groq key (it was pasted in a chat) before switching the assistant on; set ASSISTANT_ENABLED, GROQ_API_KEY, CRON_SECRET and BETTER_AUTH_SECRET on the live host.
- Run the migration on the real database only when switching the assistant on, with approval.
- After the deploy, open one real product page and place one small test order; check the live pages on a phone.
- Not tested here: voice on real phones, delivery to a real inbox, account deletion, creating campaigns and collections in the admin, bag-reminder emails with the real secret.

Rollback: revert the three newest commits or redeploy the previous version; the migration was not run, so there is nothing to undo in the database.